Which control decided? Required attribution in pre-execution payment governance

Jayath de Silva (ORCID 0009-0007-1855-4158) · Independent · Draft v0.1, October 2026

> **Preprint draft.** Complete in ten sections. Not peer reviewed, and not yet read by anyone who did not write it — which is also, as §10 argues, the paper's own open question.

Abstract

Autonomous agents can now initiate payments on settlement rails that do not govern the payer, and several systems published in 2026 place a deterministic decision before an agent's action. We do not propose another. We argue that this category, which already has independent implementations, is missing one property, and we say precisely what it costs to require it.

Under narrowing-only composition — where each control may make a verdict stricter and never more permissive — the final verdict is the join of all proposals and is therefore independent of evaluation order. **The attributed control is not.** We show that the last control to narrow is the first control in the evaluation order attaining the maximum severity, and hence that attribution depends on order *if and only if more than one control attains that maximum*. Ties are the common case rather than a corner: any two categorical refusals collide at the top of the lattice by construction. A specification that requires attribution must therefore make evaluation order normative, and must supply structure outside the lattice — declared dispositive controls — to resolve the ties the ordering alone cannot.

We make three contributions, and they are small. First, attribution as a **required and independently conformance-scorable** output: named on permit as well as on refusal, with precedence fixed in advance, checkable by a third party holding only machine-readable vectors. Second, **"bounded, not eliminated" as a disclosure obligation** — a normative requirement that an implementation state the residual its control leaves behind, with two worked cases. Third, a benchmark scoring rule, `DEFENDED_BY_ACCIDENT`, which counts *refused by a control the attack does not target* as a finding rather than a pass.

We report the reference implementation's results honestly: 20 adversarial attacks, 17 defended, one defended by accident, two open by design. We also report that the instrument has no benign scenarios, so an implementation refusing everything would score perfectly — a defect we found by reading a competitor's design rather than by testing our own. Three prior-art surveys removed three larger claims during preparation, including one we invented and withdrew within a day, and §3 reports each removal.

Keywords: autonomous agents, payment authorization, policy attribution, conformance testing, adversarial benchmarking, stablecoins.

---

1 · Introduction

An agent that can pay is an agent that can overpay, and the rails it pays over do not govern the payer.

The scale is measured rather than projected. On 21 August 2026 the x402 protocol reported **75.41 million transactions and $24.24 million of volume over 30 days** — a **$0.32 average payment** — on a protocol whose own documentation specifies no spend limits, no buyer-side authorization, and no governance layer. A settlement rail is not required to have opinions about whether a payment should happen. It is required to make it happen, and it does.

That leaves a gap that is easy to describe and awkward to fill. The seller is protected by getting paid. The chain is protected by finality. **Nobody in the transaction is positioned to ask whether the buyer should have bought**, because the only party with that interest is the buyer's principal, who is not present at the moment of payment and may not learn of it for hours.

This paper is about the layer that occupies that position, and about one property that layer should be required to have and mostly is not.

The category is not new, and saying so early is the point

Three systems published in 2026 place a deterministic decision before an agent's action. **OAP** intercepts tool calls at the framework layer and returns `ALLOW`, `DENY` or `ESCALATE` from a signed policy pack, with an Ed25519 decision record per call [1]. **PCAS** compiles policy into a Datalog-derived reference monitor and reports moving policy compliance from 48% to 93% across frontier models. **PayBench** benchmarks agents holding delegated payment authority across 226 scenarios built as 113 matched trap/lookalike pairs [4].

OAP's own discussion observes that it and PCAS *"independently converge on the need for deterministic pre-action enforcement as a distinct architectural layer … This convergence suggests the category is real, not an artifact of a single system's design."*

We agree, and we are the third data point rather than the first. A paper introducing this category would be introducing something with several independent implementations. What follows is therefore not a proposal for a layer. It is an argument about one output that layer should be obliged to produce, and evidence that the obligation is currently absent.

Contribution

1. **Attribution as a required and independently scored output** — the record must name the control that decided, on **permit** as well as on refusal; must resolve **which** control is reported when several would have refused; and must name the step that limited a delegated authority. Requiring it forces a normative evaluation order even though the verdict itself is order-independent (§5).
2. **"Bounded, not eliminated" as a disclosure obligation** — a specification clause requiring an implementation to state the residual its control leaves behind, with two worked cases (§7).
3. **A scoring rule**, `DEFENDED_BY_ACCIDENT`: in an adversarial benchmark of a control layer, counting *refused by a control the attack does not target* as a finding rather than a pass (§6).

These are small. Three prior-art surveys removed three larger claims, one of which we invented and withdrew within a day, and §3 reports what each removed. We think the remaining three are correct and unclaimed, and we would rather defend three narrow things than lose an afternoon of a reviewer's time to a fourth.

---

2 · Why irreversibility moves the control point

The controls in this space look unusual until the settlement properties are stated, after which they look forced.

A card payment is a promise that can be broken. Authorization, clearing and settlement are separate events; a cardholder can dispute; an issuer can charge back; a network can reverse. This gives the whole system a property that shapes every control built on it: **a detective control still works.** Finding a fraudulent transaction on Tuesday can undo a payment made on Monday, so it is rational to invest heavily in monitoring, scoring and review after the fact.

A stablecoin transfer on a public chain has none of that. There is no chargeback, no recall, and no issuer standing behind the payer. Once the transaction is final, a control that notices a problem has produced **a description of a loss, not a recovery.**

Two consequences follow, and they are the reason this layer is shaped as it is.

The control point moves to before execution. Not because pre-execution controls are better in general — they are worse in one important way, discussed below — but because after execution there is nothing left for a control to do except write things down.

A refusal costs something and must be accounted for. A control that refuses a legitimate payment on an irreversible rail has not merely inconvenienced anyone; it has failed to buy something the principal wanted, and there is no dispute process to correct it. This cuts directly against the instinct to refuse when uncertain, and it is why the benchmark in §6 treats over-refusal as a defect rather than as caution — and why, in §9, we report that our own instrument fails to measure it.

The honest cost of moving early. A pre-execution control decides on less information than a post-hoc one. It cannot see whether the goods arrived, whether the counterparty later proved fraudulent, or whether the same pattern repeated across a hundred other principals. Systems that monitor after the fact see all of that. **We are not claiming the earlier control is more accurate. We are claiming it is the only one whose output can still change the outcome**, and that this makes the accuracy trade a forced one rather than a chosen one.

---

3 · Related work, and what each survey removed

This section is longer than the contribution it supports. That ordering is deliberate: three surveys removed three claims, and the credibility of what is left rests on showing the removals rather than the survivors.

3.1 Contemporary pre-action authorization

OAP [1] is the closest work. It is deterministic (*"Same inputs, same decision. No sampling, no temperature"*), bypass-resistant by running at the framework layer rather than in the model's reasoning, fail-closed, and auditable — every decision produces a signed, timestamped record. Denials carry a structured reason code such as `oap.limit_exceeded` or `oap.merchant_forbidden`, plus a human-readable explanation. It was evaluated against **4,437 adversarial decisions across 1,151 attack sessions** in a live capture-the-flag against a banking agent, with external participants.

That last figure is better than anything we report, on the axis we identify in §9 as our weakest: our attacks were written by the author of the system under test, and OAP's were not.

OAP's own limitations record that it does not formalise a delegation model (*"planned for v1.1"*), that its `ESCALATE` path is specified but unimplemented in the reference, and that attack sequence-based structuring is future work.

PCAS [2] is the strongest academic work in this space and the closest to ours in ambition, though not in subject. Its system, FORGE, models an agentic execution as a **dependency graph of causal relationships** between messages, tool calls and tool results, rather than as a linear history — because policies whose satisfaction depends on information flow cannot be expressed over a transcript. Policies are Datalog-derived rules accounting for transitive flow and cross-agent provenance; a reference monitor intercepts every action and blocks violations before execution. It reports policy compliance rising from 48% to 93% across frontier models on a customer-service benchmark, with case studies in prompt-injection defence, multi-agent approval workflows, and organisational policy.

Two distinctions matter for what follows, and both required reading the paper rather than OAP's description of it.

PCAS attributes events to entities, not decisions to controls. It defines a principal function mapping each event to its producing entity, which answers *who acted*. Our claim concerns *which control decided*, and the paper contains no occurrence of the question in that sense. **This is a third independent system placing a deterministic decision before an action without requiring the record to name the control that produced it**, which is the strongest support claim 1 has.

Its subject is information flow; ours is money. FORGE governs any tool call and reasons about what an action depends on. It has no notion of an envelope, of integer minor units, of settlement, or of an irreversible rail. Payments appear in its evaluation only as domain content in a retail benchmark — tracking which payment method an order used — rather than as a governed economic quantity. Neither system subsumes the other, and saying so plainly is more useful than claiming adjacency. **PayBench** [Plunkett 2026] benchmarks agent behaviour under three control conditions — no policy, prompt-based policy, hard tool constraints — using matched trap/lookalike pairs so that blanket refusal cannot score well. **EcoAgent-Bench** scores agents' economic decision *quality* under budget constraints rather than enforcement. **Faramesh** is an execution-time control plane; **ToolMisuseBench** is an offline deterministic harness isolating failure origin between call construction, policy handling and recovery.

3.2 Policy languages and authorization

XACML 3.0 responses **may** carry a `PolicyIdentifierList`, so *"which policy decided"* has been expressible in a 2003-lineage standard for two decades. **OPA** and **Cedar** are the modern expression of policy-as-data. Our claim is therefore not that attribution is inexpressible or unprecedented; §3.5 states what remains.

3.3 Capability-based security — and the claim it removed

SPKI/SDSI (1996) provides authorization certificates that delegate, and a reduction algorithm computing effective authority through a certificate chain. **Macaroons** (2014) provide caveat attenuation. The **object-capability** model provides attenuating proxies and the **membrane** pattern

for transitive attenuation. Intent-Driven Computing [3] proves that *"capabilities can only narrow, never widen, through composition"* with a mechanised Coq proof.

An earlier version of this paper claimed a narrowing-only delegation clamp as a contribution, on the basis that OAP lists delegation chains as unformalised. **That was true about OAP and wrong about the field, and the claim is withdrawn.** Narrowing-only delegated authority is a thirty-year-old standard with a machine-checked proof.

What the surveyed work computes or proves is the *result* of attenuation. None of it names **the step that produced the result** — and that is an attribution property, not a delegation one, so it appears in claim 1 and is not counted separately.

3.4 Transparency logs — and the claim they shrank

Certificate Transparency commits a log to a signed tree head, which is exactly a `(length, head)` pair over an append-only structure. Our evidence anchoring is that mechanism applied to a spend journal. The survey that established this **refuted** the novelty we had claimed for it; the clause survives as engineering, not as contribution.

3.5 What is left after all of it

Every surveyed system that attributes at all attributes a **refusal**. OAP's reason codes attach to `DENY`. XACML permits a policy identifier in a response but requires nothing. None of the surveyed work:

- requires the record to name the control that **permitted** an action;
- defines **precedence** when several controls would each have refused, so that the reported control is determined rather than incidental;
- makes the presence of attribution **independently scoreable** by a third party holding only machine-readable vectors and no access to the implementation;
- states the **order asymmetry** — that the verdict is order-independent while the attribution is not, so requiring attribution forces a normative evaluation order.

Those four are claim 1.

3.6 Adjacent work not surveyed

Transaction monitoring and AML systems, cloud and FinOps quota systems, NIST AI RMF and EU AI Act traceability, and agent governance frameworks beyond Microsoft's Agent Governance Toolkit remain **unsurveyed at the time of writing**. We do not believe they touch the three surviving claims. We believed the same about capability-based security on the morning of the day it removed one.

---

4 · Definition

> An **autonomous economic governance layer** renders a deterministic, attributable verdict on a proposed economic action **before that action is executed**, and emits evidence sufficient to reconstruct which control produced the verdict.

Four elements, each doing work.

Deterministic. Same inputs, same verdict, replayable from the record. This excludes a model sampling at temperature above zero from the decision path. It does not exclude a model from the system: an advisory component may *narrow* a verdict and may never widen one, which keeps the decision reproducible while allowing judgement to make it stricter.

Attributable. The record names the control that produced the verdict. This is the property the paper argues should be required, and §5 is about what it costs.

Before execution. The verdict is rendered while refusal is still free. After execution a control can only describe.

Evidence sufficient to reconstruct. Not a log line asserting a conclusion, but enough state to re-derive it — the inputs, the policy identity, and the control that decided.

The definition deliberately includes card authorization

A card authorization system satisfies every element. It decides before the money moves, it decides deterministically from rules the issuer set, it returns a reason code, and it keeps a record. **ISO 8583 has carried a decline-reason field since the 1980s.**

We consider this a feature of the definition rather than a flaw in it. A definition of *governance layer* that excluded the most widely deployed governance layer in the world would be a definition built to make its author's system look novel. **The interesting question is not whether card authorization qualifies — it does — but what changes when the payer is software acting under authority conferred earlier, on a rail with no chargeback, at a rate no cardholder generates.**

That framing also supplies the strongest objection to claim 1, from the same source. Card networks deliberately **do not** tell the cardholder which rule declined them, because a declined fraudster who learns the rule can work around it. Attribution is a genuine security cost, not a free good.

Our answer is narrow and depends on who reads the record: **in this setting the reader is the operator who wrote the policy.** A principal reading their own agent's refusal is not an adversary probing an issuer's fraud model; they are the party who set the limit and now need to know which limit bound. Where a record is disclosed to a counterparty, that is a different audience and the projection is different — the layer described here discloses a strict subset to a seller and never includes which control decided.

5 · Attribution, and the order it forces

This is the paper's principal claim, and it can be stated as a single observation about narrowing systems.

5.1 The verdict is order-independent; the attribution is not

Take a layer whose controls may only *narrow* a standing verdict — each control may make the outcome stricter and may never make it more permissive. Order the verdicts by severity: `APPROVE`, `REVIEW`, `ESCALATE`, `REJECT`.

Under narrowing-only composition the final verdict is the **maximum severity any control proposed**. Maximum is commutative and associative, so **the final verdict does not depend on the order the controls ran in.** This is a pleasant property and every system in §3 has some version of it.

Now ask a different question: *which control decided?*

Define the attributed control as **the last control that narrowed** — well defined because widening is impossible, so a control proposing something no stricter than the running verdict changes nothing.

There is an exact condition for when that answer depends on order, and it is narrower than we first claimed. Once the running verdict reaches the maximum, no later control can narrow. So the last narrower is the **first control in the order attaining the maximum severity**, and therefore:

> **Attribution depends on evaluation order if and only if more than one control proposes the maximum.**

An earlier draft of this paper, following the specification's own rationale, illustrated order-dependence with a treasury envelope narrowing to `REVIEW` and a risk score then narrowing to `ESCALATE`. **That example is wrong.** `ESCALATE` is attained only by risk, so risk is attributed under both orders; the example shows the verdict is order-independent and shows nothing about attribution. Formalising the lattice caught it, and both the specification and this section are corrected.

A witness needs a tie. A sanctioned counterparty whose payment a spending limit also refuses: both propose `REJECT`, and whichever runs first is the sole narrower and takes the attribution.

Ties are the common case, not a corner. Any two categorical refusals collide at the maximum by construction — barred counterparty, exhausted budget, revoked identity all produce `REJECT`.

So the moment a specification requires attribution, it has acquired an obligation the verdict never imposed: it must say something normative about evaluation order. It cannot know in advance whether a given decision has a tie at the top, so it must fix the order for all of them. Not because order changes what happens, but because order changes what the record says about what happened.

That is the asymmetry. It is why attribution is not a free addition to a narrowing system, and it is why, we suspect, no surveyed system requires it: the verdict is the part that matters operationally, the verdict is order-free, and it is easy to conclude that order therefore does not need specifying.

5.2 "The last control that narrowed" is well defined, and insufficient

The default attribution rule is *the last control that narrowed the verdict*, and it is well defined precisely because widening is impossible. A control proposing something no stricter than the standing verdict changes nothing, so it did not narrow. The final narrowing is therefore unique.

The rule is a good default and it fails on a case that matters. Consider a sanctioned counterparty whose payment a spending limit also refuses. The limit narrowed. The sanctions screening did not — the verdict was already `REJECT` when it ran. Under the default rule the record attributes the refusal to the **budget**.

That record says an agent was stopped by a spending limit. The truth is that it tried to pay a sanctioned party. An operator who responds by raising the limit finds the payment still refused, with nothing on the record explaining why.

Some findings are categorical rather than quantitative. A counterparty is barred or it is not, and that does not become less true because a second constraint happened to bite first. So a specification that requires attribution must also let an implementation declare certain controls **dispositive**: their finding determines attribution whenever it is *present*, whether or not it narrowed anything.

The formalisation explains why this mechanism is forced rather than convenient. **A total order on verdicts cannot distinguish two controls that both reach the maximum** — the lattice has no structure left to break the tie with. Something outside it must, and a declared precedence among dispositive controls is that something. Where such a finding is present, attribution stops reading the evaluation order at all and is order-independent by construction.

This clause exists because the earlier version was wrong and a conformance vector caught it. We report that rather than presenting the final rule as though it were the first one, because a specification whose errors are visible is easier to trust than one whose history is not.

5.3 Declaration is what stops this being an escape hatch

An implementation free to nominate any control as dispositive after the fact can attribute a decision to whatever is convenient. Two requirements prevent that:

- the set of dispositive controls and **their precedence relative to one another** must be fixed in advance and in writing;
- the evaluation order must be **documented**, not fixed by the specification.

The second is deliberate and slightly uncomfortable. A standard cannot impose a sequence, because it does not know which controls a given implementation has. But an implementation whose order is undocumented has an attribution nobody can predict, and therefore **an attribution nobody can audit** — which is the entire failure this section exists to prevent.

There is a consequence worth naming: a dispositive control must record its finding *unconditionally*, because attribution now depends on the finding being present rather than on its having changed the outcome. A control that stays silent when it did not narrow cannot be dispositive.

5.4 Attribution on permit, which no surveyed system requires

Every system in §3 that attributes at all attributes a **refusal**. OAP's reason codes attach to `DENY`. This is the natural place to start: a refusal demands an explanation because somebody is inconvenienced by it.

A permit is the more interesting record. *"This payment was approved, and the control that let it through was the budget envelope with $12.40 of headroom"* answers a question a refusal record cannot: **would deleting this control have changed anything observable?** A layer whose controls all silently permit is indistinguishable from a layer with no controls at all, and the only way to tell them apart from the outside is to require the permit path to name its decider too.

5.5 The property this buys, stated as a test

The reason to require attribution rather than encourage it is that it converts an untestable assurance into a testable one.

> **Delete a control. Does any record change?**

If the answer is no, that control was decorative and its removal is invisible to every audit. This is checkable by a third party holding only the record format and a set of vectors — no access to the implementation, no cooperation from its author. That is what "independently scored" means here, and it is the part §3.5 identifies as unclaimed.

---

6 · The scoring rule, and the instrument under it

6.1 `DEFENDED_BY_ACCIDENT`

An adversarial benchmark of a *control layer* normally has two outcomes per attack: the attack succeeded, or it did not. We use four, and the third is the contribution:

Outcome	Meaning
`DEFENDED`	Refused, by the control the attack targets
`DEFENDED_BY_ACCIDENT`	Refused, by a control that was not aiming at this attack
`UNDEFENDED`	Not refused
`ERROR`	The attack did not execute

`DEFENDED_BY_ACCIDENT` is scored as a finding, not as a pass, and the reason is that a coincidence has no maintenance contract. A trust-farming attack refused by a risk score that happened to fire is refused today and may not be refused after an unrelated weight is retuned. The record will not show a regression, because nothing that was ever asserted stopped being true.

Requiring attribution (§5) is what makes this outcome *observable*. Without a record naming the control that refused, an accidental defence and an intentional one look identical from the outside — which is the practical argument for claim 1 restated as a measurement.

No system surveyed in §3 has this outcome. OAP records a deny code but does not ask whether that code was the one aiming at the attack; PayBench scores whether a refusal was appropriate, not where it came from.

The most recent addition found a defect rather than confirming one. Two advisor-path attacks were added in August 2026, assuming a counterparty's text fully compromises the advisory model. The first confirmed the clamp holds. The second — an advisor returning a string that is not one of the four verdicts — raised an unhandled exception out of the decision path, so the layer *failed closed by crashing*: no verdict, no attributed control, no record. **A decision that never finishes has none**

of the four states to report, which is a failure mode the state vocabulary cannot express and the benchmark can.

`ERROR` is separated from the other three for a reason found the hard way: an attack with no handler silently reports nothing, and a suite full of errors looks like a clean run to anyone reading only a failure count. A test asserts every attack executed.

6.2 The instrument, and what is wrong with it

Twenty attacks across five classes — numeric, economic, evidence, authority, advisor. The current score is **17 defended, 1 by accident, 2 undefended, 0 errors**, recorded in a sealed experiment record with a checksum. A test compares a live run against that record and **fails on any difference in either direction**: a closed gap is as much a deliberate change as a regression, and both must be committed with the record updated.

Three properties of the instrument we state here rather than in the limitations section, because a reader should not have to reach §9 to learn them:

It is smaller than the alternatives and it is not externally attacked. OAP's CTF produced 4,437 adversarial decisions across 1,151 sessions with external participants. Ours has twenty attacks, all written by the author of the system under test. On the axis of independence, we are behind the work we are citing.

It has no benign twins. PayBench pairs each trap scenario with a lookalike that is safe to permit, so an agent that refuses everything cannot score well. **We have no such pairing.** An implementation that refused all twenty attacks would score 20/20 on our instrument, which means the instrument does not measure over-refusal at all — the failure mode §2 argues is expensive on an irreversible rail. This is a genuine defect and it was found by reading a competitor's design rather than by testing our own.

Two findings are open and stay open. Structuring is bounded rather than refused, for reasons given in §7. Journal truncation is closed only against an external anchor, and no anchor ships by default, so the benchmark reports the posture an installer actually gets rather than the one available to a careful operator.

6.3 The lineage, including a wrong measurement

The record chain behind the score is `EXP-008 → EXP-009 → EXP-010`. `EXP-009` **supersedes** `EXP-008` because a measurement in it was wrong: an attack was parameterised over a window its target control could not observe, so the result described the parameterisation rather than the control.

The superseded record was not edited. It remains, marked superseded, with the reason attached.

We include this because a record lineage containing a correction is better evidence about method than a clean one. A benchmark whose history shows no errors is either very carefully run or very carefully tidied, and a reader has no way to tell which.

---

7 · Bounded, not eliminated

The third claim is a specification obligation: **where a control bounds a risk rather than eliminating it, the specification must require the implementation to say so.**

This is unusual. Standards ordinarily specify what a control must *do*. The clause here specifies what an implementation must *admit* about the residual its control leaves behind — and both cases below ship with a conformance vector that asserts the limit, so the admission is scored rather than narrated.

7.1 Count envelopes: unbounded becomes bounded-by-a-number

A rate limit bounds how *fast* an agent acts. A value envelope bounds how *much* it spends. Neither bounds **how many times it acts over a window longer than the rate limit's**, and nothing multiplied *trivial* by *many* and compared the product to anything.

The measured consequence: an agent pacing at **97 actions an hour — three per cent under a ceiling of 100 — was compliant indefinitely**, at 2,328 actions a day for $2.33 against a $50 daily budget. Every value envelope was out of reach because each action was trivial. Every rate limit was out of reach because the pacing sat under it.

A cumulative count envelope closes it: the paced-evasion attack moved from undefended to defended, refused at action 500 and attributed to the treasury control citing `actions_per_day`.

What it does not do is eliminate structuring, and the specification requires saying so. Forty payments of $0.001 five minutes apart total $0.04 and are nowhere near 500 actions. The envelope bounds the mechanism at a number the operator chose; it does not refuse this instance.

And it should not. Forty trivial purchases in an afternoon is also what a legitimate agent does. A control that refused it would be producing a false positive on an irreversible rail, which §2 argues is a real cost rather than a safe default. The honest statement is *bounded at a number you chose, not eliminated* — and the attack remains in the benchmark as `UNDEFENDED` rather than being reclassified.

7.2 Anchoring: detectable, beyond a bound the operator chose

A hash chain detects edits and cannot detect truncation of its own tail, because **any prefix of a valid chain is itself a valid chain.** The missing information is *that there was more*, and no amount of internal linking supplies it.

An external anchor supplies it: a `(length, head)` commitment published where the journal's writer cannot reach. This is Certificate Transparency's signed tree head applied to a spend journal, and §3.4 records that the survey establishing this refuted the novelty we had claimed for the mechanism.

The bound is the honest part. An anchor is published at some cadence, so everything appended since the last publication is unattested and remains silently truncatable. Anchoring does not make truncation detectable; it makes truncation detectable **beyond a bound the operator chose**. A vector asserts the difference rather than describing it.

Verification therefore has four outcomes, not two: `consistent`, `truncated`, `diverged`, and `unknown` — and **`unknown` is never a pass.** An anchor that cannot be read is a fact about the anchor, and reporting it as agreement would let anyone able to partition the verifier from the sink also make the journal verify.

No anchor sink ships with the implementation. An append-only file beside the journal is that journal at one remove in any deployment where the agent's own host can rewrite it, and shipping one would make the gap *look* closed.

8 · What the measurements cost

A pre-execution control sits on the critical path of every payment, so its cost is a design constraint rather than a footnote. The measurement is reported here with its variance, because the variance turned out to be the finding.

8.1 The numbers

Three thousand decisions across ten runs, against the **published package installed from PyPI into a clean virtual environment** — the artefact a user gets, not a source checkout.

	Median across runs	Range	Spread
p50	**168 µs**	139–330 µs	**2.37×**
p99	397.5 µs	272–1,218 µs	4.5×

Zero model invocations. $0.00 inference cost. The decision path invokes nothing probabilistic, which is what makes the figure a property of the code rather than of a provider's queue.

8.2 The variance is the result

Ten identical runs of the same measurement produced p50 figures spanning **2.37×**. The instrument is one laptop, shared with other work while measuring, and that is stated in the sealed record's limitations rather than discovered by a reader.

The consequence is a rule rather than a caveat: **any single-run figure for this measurement carries no error bar and must not be quoted as precise.** That applies to our own earlier records. An earlier experiment reported **128 µs** from a single run — a number that sits *below the minimum* of the ten-run distribution measured later. It was not wrong when taken. It was unrepeatable, and quoting it would have implied a precision the method never had.

We report this because a latency figure with no distribution behind it is the easiest number in this field to publish and the least useful to receive.

8.3 The comparison we are not making

OAP reports **53 ms p50** for its cloud API and **174 ms** for local evaluation. Ours is 168 µs. That looks like three orders of magnitude and **it is not a like-for-like comparison, so we do not make one.**

OAP's cloud figure includes server-side processing at an edge network and excludes the client's network round-trip; its local figure is dominated by Python subprocess overhead. Ours is an in-process function call with no network, no subprocess and no signature verification on the path. **These measure different architectures answering to different deployment requirements** — a portable credential verified by an independent service is doing work an in-process library does not do, and that work is the reason someone would choose it.

The honest statement is narrow: **a deterministic pre-execution decision need not cost a network round-trip**, and where the layer runs in the agent's own process it does not. Whether that matters depends entirely on whether the deployment can tolerate the trust assumption that comes with it, which §9 records as a limitation rather than resolving.

---

9 · Limitations

This section is the union of the limitations sections of every sealed record cited, plus the ones that belong to the work as a whole. It is not a summary of them.

9.1 The benchmark

Every attack was written by the author of the system under test. This is the single largest hole in the paper. An adversarial benchmark authored by the defender measures what the defender thought to try, and the correlation between that and what an attacker would try is unknown. OAP's capture-the-flag with external participants is better on exactly this axis and we say so in §3.1.

There are no benign twins, so over-refusal is unmeasured. An implementation refusing all twenty attacks scores 20/20 on this instrument. PayBench's matched trap/lookalike pairing exists precisely to prevent that, and adopting it would change what our score means. **Until it is adopted, the score should be read as an upper bound on defence and as silent about false positives** — which §2 argues is the expensive failure on an irreversible rail.

Twenty attacks is small, and the five classes were chosen by the same author.

The threat model is an adversarial agent, not an adversarial host, and one measured exposure falls outside it. The value envelopes sum settled rows only, so an authorisation nobody reports back on consumes no budget: ten $9 authorisations against a $50 daily ceiling leave the counter at zero. An attack was written for this and **withdrawn**, because the agent does not control whether settlement is reported — that is the embedding process, which this model trusts. Shaping it into an agent attack would have meant granting the adversary a capability the model does not give it in order to produce a finding. The exposure is real, is reported by a separate reconciliation surface, and is named here rather than counted in the score.

A threat model in which the embedding process is untrusted is defensible — it is what a provider running someone else's agent code would want — and it is not the one measured here.

9.2 The measurements

One laptop, shared with other work, Windows 11. p50 varies 2.37× across identical runs. No measurement here was taken on server hardware, under concurrency, or with a cold cache. The p99 figures span 272–1,218 µs and no claim is made about tail behaviour under load.

Nothing was settled and no model was invoked: this is the decision path in isolation, not an end-to-end payment.

9.3 The specification and the standard

There is one implementation, and the same person wrote both it and the standard. A specification with a single implementation is a description of that implementation, and no amount of further work by that person changes it. Machine-readable vectors and a conformance suite that installs separately exist so a second implementation is possible without permission; whether one appears is outside our control and is the open question of §10.

Four adjacent fields remain unsurveyed — transaction monitoring and AML, cloud and FinOps quota systems, AI governance frameworks, and agent governance beyond Microsoft's toolkit. We do not believe they touch the three surviving claims. We believed the same about capability-based security on the morning of the day it removed one, and §3.3 records the result.

9.4 Scope

One rail. Everything measured here is x402 and stablecoin settlement. The card, AP2 and bank bindings are specified as shapes and not implemented, so any claim about generality is untested.

Two red-team findings are open by design. Structuring is bounded rather than refused (§7.1); journal truncation is closed only against an external anchor and no anchor ships (§7.2).

No compliance is claimed with any framework. The obligations discussed in §2 and §4 attach to issuers, service providers and obliged institutions. The layer described here is a library and is none of those. It consumes compliance signals and does not produce them: it performs no sanctions screening, holds no list, and implements no transfer-information protocol.

The AML profile it defines, it does not meet. The specification defines a vertical conformance profile requiring a recorded AML position, and the reference implementation **does not conform to it** — there is no AML control, so no assessment key is emitted. We regard a profile the reference implementation fails as better evidence that the profile measures something than one it passes.

---

10 · Conclusion, and the question we cannot answer

The argument of this paper is small and can be restated in three sentences.

Where a control layer decides before an irreversible payment, the verdict is order-independent and the attribution is not — so a specification that requires attribution must also make evaluation order normative, and one that does not require it cannot tell a working control from a decorative one. Where a control bounds a risk rather than removing it, the specification should require the implementation to say which, because *bounded at a number you chose* and *eliminated* are different promises and only one of them is usually true. And where a benchmark scores a control layer, a refusal by a control that was not aiming at the attack is a coincidence rather than a defence, and counting it as a pass rewards the wrong thing.

None of these needs the layer we built. They are properties a specification can require of anything in this category, and the category now has several independent implementations, none of which requires them.

The open question

A conformance standard exists to let someone check an implementation they did not write. This one has been checked only by its author, against an implementation by the same author, using vectors by the same author. Every mechanism that would make third-party validation possible is in place — machine-readable vectors, a suite that installs separately and scores a record it has never seen before, profile manifests that are data rather than code — and none of it constitutes evidence that anyone else can or will do it.

So the honest closing question is not whether the claims in this paper are true. It is whether a governance standard can be validated by anyone other than its author, and we have no way to answer that from inside.

The three surveys in §3 are the closest thing to an answer we have: each removed a claim by consulting people who owed us nothing, and one removed a claim we had invented that same day. That is what external validation feels like from the receiving end, and it is the argument for wanting more of it rather than less.

References

Marked by how each was consulted, because the paper argues that provenance should be visible and it would be strange to exempt its own bibliography. **`[read]`** — the source text was retrieved and read. **`[secondary]`** — consulted through summaries or through another paper's description.

[1] `[read]` U. Uchibeke. *Before the Tool Call: Deterministic Pre-Action Authorization for Autonomous AI Agents*. APort Technologies, arXiv:2603.20953, March 2026. CC BY 4.0. Specification released under Apache 2.0, DOI 10.5281/zenodo.18901596. *Retrieved and read in full; all quotations in §3.1 and §5 verified against the PDF text.*

[2] `[read]` N. Palumbo, S. Choudhary, J. Choi, G. Amir, P. Chalasani, S. Jha. *Policy Compiler for Secure Agentic Systems*. University of Wisconsin–Madison, Cornell University, Langroid. arXiv:2602.16708, 2026. The system is named FORGE. *Retrieved and read 2026-08-30, having been flagged in the first version of this bibliography as characterised only through [1]'s description of it. Reading it changed §3.1: the paper attributes events to entities via a principal function, which is a different question from which control decided, and it contains no occurrence of the latter — making it a third independent confirmation rather than a competitor for claim 1.*

[3] `[read]` *Intent-Driven Computing: A Computational Model for Governed Autonomous Systems*. arXiv:2605.24036, 2026. *Retrieved and read; the narrowing-under-composition property and its mechanised proof (`CompositionPreserves.v`) verified in the source text.*

[4] `[secondary]` C. Plunkett. *PayBench: A Benchmark for Unsafe Commercial Autonomy in AI Agents with Delegated Payment Authority*. 2026. `paybench.org`. *Design and scale read from the project site; the matched trap/lookalike construction described in §3.1 and §6.2 comes from that source, not from running the benchmark.*

[5] `[read]` Financial Action Task Force. *International Standards on Combating Money Laundering and the Financing of Terrorism & Proliferation — The FATF Recommendations*. Consolidated text,

2012–2025. fatf-gafi.org. *Retrieved 2026-08-28 and read; the required data set of INR.16 ¶9 and the glossary definition of "originator" verified directly.*

[6] [read] Financial Action Task Force. *Explanatory note for revised R.16*. June 2025. fatf-gafi.org. *Retrieved 2026-08-28 and read; the "allows" → "requests" redline verified against the adopted text of [5].*

[7] [secondary] Clearstream. *Usage Guideline CBPR+ pacs.008.001.08 — FIToFICustomerCreditTransfer. The `InitiatingParty [0..1]` and `UltimateDebtor [0..1]` elements were read from this usage guideline, which is an implementation profile of ISO 20022 rather than the standard itself.*

[8] [secondary] interVASP Messaging Standard, IVMS101. *Data model consulted through published documentation rather than the standard text; the absence of an initiating-party element in §2.1 is stated on that basis.*

[9] [read] A. Birgisson, J. G. Politz, Ú. Erlingsson, A. Taly, M. Vrable, M. Lentczner. *Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud*. Network and Distributed System Security Symposium (NDSS), 2014. DOI 10.14722/ndss.2014.23212. *Retrieved and read 2026-10-24; title, authors and the attenuation property ("caveats that attenuate and contextually confine") verified in the paper's text. The DOI printed in the NDSS PDF header, 10.14722/ndss.2014.23208, resolves to a different paper; the one given here was checked at doi.org.*

[10] [read] C. Ellison, B. Frantz, B. Lampson, R. Rivest, B. Thomas, T. Ylonen. *SPKI Certificate Theory*. RFC 2693, Experimental, September 1999. *Retrieved and read 2026-10-24. The claim §3.3 draws from it is in §6.3: two 5-tuples reduce to one whose authorization is `AIntersect(A1, A2)` and whose validity is `VIntersect(V1, V2)` — effective authority through a delegation chain is the intersection, which is the clamp this paper concedes.*

[11] [read] B. Laurie, A. Langley, E. Kasper. *Certificate Transparency*. RFC 6962, Experimental, June 2013. *Retrieved and read 2026-10-24; the signed tree head of §3.5 signs `tree_size` and `sha256_root_hash` — the `(length, head)` commitment §3.4 concedes the anchoring mechanism to.*

[12] [secondary] OASIS. *eXtensible Access Control Markup Language (XACML) Version 3.0*, 2013. *The optional `PolicyIdentifierList` in a response is the basis of §3.2 and was read in secondary description rather than in the specification.*

[13] [read] AEGS — *Autonomous Economic Governance Standard*, version 0.1. github.com/tesoro-labs/aegs. The specification this paper's claims are expressed in: 95 clauses, 167 machine-readable conformance vectors, four profiles. CC BY 4.0.

[14] [read] tesoro, version 0.1.2. github.com/tesoro-labs/tesoro, pypi.org/project/tesoro. The reference implementation. Apache 2.0.

[15] [read] Sealed experiment records EXP-007 through EXP-010, github.com/tesoro-labs/aegs/tree/main/research/experiments. Every measured figure in §6 and §8 resolves to one of these, each carrying a checksum and its own limitations section. EXP-009 supersedes EXP-008 because a measurement in it was wrong; the superseded record is retained unedited.

[16] `[secondary]` Financial Crimes Enforcement Network and Office of Foreign Assets Control. *Permitted Payment Stablecoin Issuer AML/CFT Program and Sanctions Compliance Program Requirements*. Notice of proposed rulemaking, Federal Register, 10 April 2026. *Read through the Federal Register listing and published law-firm analyses;* ***the NPRM itself was not read****.*

[17] `[secondary]` Sumsub. *Stablecoin compliance in 2026: which rules apply to your business*. The seven frameworks and six obliged-entity segments used in §2 and §4 are that document's structure, credited as its analysis rather than presented as ours.

A note on this bibliography

Ten of seventeen entries are marked `[read]`. The rest were consulted at one remove, and each says how.

Entry `[2]` moved from `[secondary]` to `[read]` on 2026-08-30, and the move changed §3.1 rather than merely upgrading a label — which is the argument for retrieving sources you have only heard described.

Marking them is not modesty. This paper's central argument is that a record should say which control decided, and its method section claims that a source able to kill or save a claim gets read in its own text. A bibliography that presented all seventeen as equally consulted would contradict both positions on the last page.

Entries `[9]`–`[11]` moved from `[unverified]` to `[read]` on 2026-10-24. Each concession stood — macaroons attenuate, CT commits to a tree head, SPKI reduces a chain by intersection — and checking them still found something: the DOI printed on the Macaroons paper's own first page points at a different paper. A citation copied from the source is not thereby a checked citation.